第3章 操作系统安全

目录

01 操作系统概述
02 操作系统的安全要求
03 操作系统的安全机制
04 操作系统安全设计
05 操作系统的安全威胁和防范

01 操作系统概述

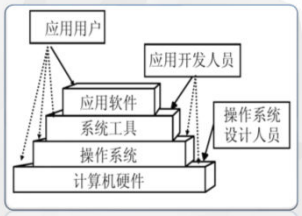
操作系统概述

目的:

- 控制和管理计算机软、硬件资源
- 为用户提供便捷使用计算机的接口(窗口、系统API)

主要功能:

- 进程/线程管理
- 内存管理
- 文件系统
- 输入/输出



02 操作系统的安全要求

操作系统的安全需求

- **系统安全性**
  - 保密性。指防止信息的非授权获取
  - 完整性。信息在存储或传输过程中保持不被修改、破坏和丢失。
  - 可靠性。系统提供信息的可信赖程度。
  - 可用性。当需要时是否能存取所需信息，防止信息失效或变得不可存取。
- **操作系统安全的目标**
  - 为用户信息处理提供安全的软件环境
  - 为应用程序运行提供安全可靠的运行环境。

6

可信系统

Can We Build Secure Systems?

1. 建立一个安全的操作系统有可能吗?
2. 如果可能，为什么不去做呢?

7

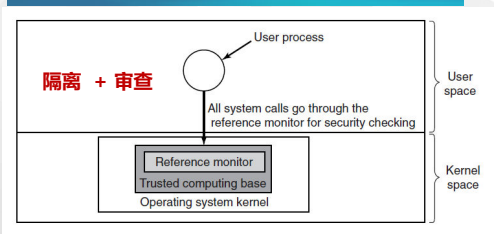
可信计算基

- **可信计算基 (Trusted Computing Base, TCB): 实现所有安全规则所必需的硬件和软件，包括:**
  - **大多数的硬件(除了不影响安全性的I/O设备)**
  - **操作系统的部分核心：进程创建/切换、内存管理、部分文件和I/O管理**
  - **掌握超级用户权限或管理员权限的用户程序**

TCB通常独立于操作系统的其他部分

8

访问监视器



9

操作系统安全的评估与标准

A 级	形式化校验级保护，SNS
B3 级	安全内核，高抗渗透能力，Trusted Mach
B2 级	结构化内容保护，正式安全策略模型，MULTICS
B1 级	标记安全保护，如System V等
C2 级	C1+访问控制，广泛审核，Linux/WINDOWS NT
C1 级	主体自主决定的安全保护，UNIX/WINDOWS
D 级	不分等级，无口令和权限控制，MS DOS

10

03

操作系统安全机制

操作系统的安全机制

硬件安全机制

- 存储保护
- I/O保护
- 运行保护

软件安全机制

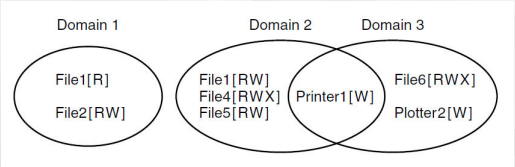
- 标识和鉴别
- 可信路径管理
- 禁止客体重用
- 最小特权管理
- 访问控制技术
- 隐蔽信道检测与控制
- 安全审计

访问控制技术

- **访问控制功能**
  - 管理所有资源访问请求，即根据安全策略的要求，对每个资源访问请求作出是否许可的判断；
- **主要访问控制策略**
  - 最小权益策略：按主体执行任务所需权利最小化分配权利。
  - 最小泄漏策略：按主题执行任务时所知道的信息最小化原则分配权利。
  - 多级安全策略：主体和客体按普通、秘密、机密、绝密等级别划分，进行权限控制。
- **主要访问控制技术**
  - 自主访问控制，强制访问控制，有限型访问控制, 共享 / 独占型访问控制

13

保护域



- **域：（对象，权限）对的集合**
- **最小权限原则：每个域都拥有最少数量的对象和满足其工作所需的最少权限时，安全性最好。**

14

保护矩阵

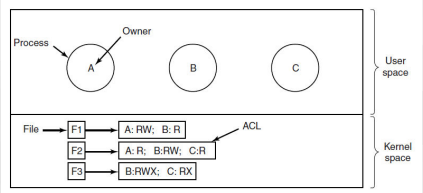
Domain \ Object	File1	File2	File3	File4	File5	File6	Printer1	Plotter2
1	Read	Read Write						
2			Read	Read Write Execute	Read Write		Write	
3						Read Write Execute	Write	Write

- **判断是否可以从指定的域以特定的方式访问特定的对象**

15

基于列的自主访问控制

- 访问控制列表ACL(Access Control List)



基于角色的自主访问控制

- 引入用户组(Group)概念的ACL

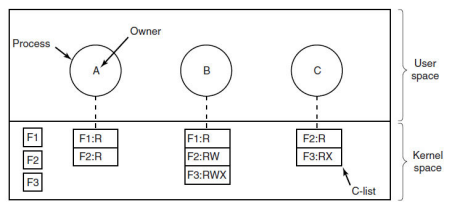
UID1, GID1: rights1; UID2, GID2: rights2; .....

- 引入角色(role)的概念

File	Access control list
Password	tana, sysadm: RW
Pigeon_data	bill, pigfan: RW; tana, pigfan: RW; ...

基于行的自主访问控制

- 权能字列表C-list(Capability List)



安全系统的形式化模式

操作系统控制的保护矩阵

	Objects		
	Compiler	Mailbox 7	Secret
Eric	Read Execute		
Henry	Read Execute	Read Write	
Robert	Read Execute		Read Write

(a)

	Objects		
	Compiler	Mailbox 7	Secret
Eric	Read Execute		
Henry	Read Execute	Read Write	
Robert	Read Execute	Read	Read Write

(b)

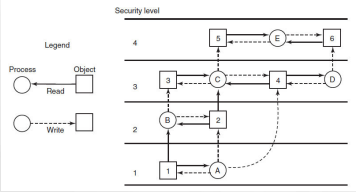
(a) 授权后的状态　　(b) 未授权的状态

强制（多级）访问控制

- **强制性的访问控制**
  - 控制管理整个信息流，确保不会泄露那些不应该泄露的信息；
- **Bell-LaPadula模型**
  - 多级安全策略：主体和客体按普通、秘密、机密、绝密等级别划分，进行权限控制。
  - 简易安全规则：在密级k上面运行的进程只能**读取**同一级或更低密级的对象
  - *规则：在密级k上面运行的进程只能**写**同一级或更高密级的对象

- **进程即可下读也可上写，但不能颠倒，保证信息不会从高一级泄漏到低一级**

Bell-LaPadula多级安全模型



- **可用于保守秘密，但不能保证数据完整性。**
- **用在类军事单位的信息系统中**

强制访问控制

- **Biba模型**
  - 多级安全策略：主体和客体按普通、秘密、机密、绝密等级别划分，进行权限控制。
  - 简单完整性规则：在密级k上面运行的进程只能**写**同一级或更低密级的对象(没有往上写)
  - 完整性*规则：在密级k上面运行的进程只能**读**同一级或更高密级的对象(不能往下读)

- **保证数据完整性。**
- **用在类公司的信息系统中**

04

操作系统的安全设计

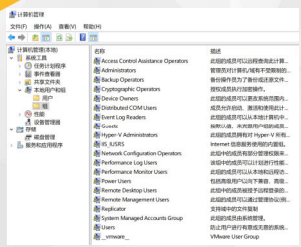
操作系统的安全设计

- 对用户标识和鉴别
- 对内存的保护
- 对文件和 I/O设备的访问控制
- 对共享资源的分配控制
- 保证系统可用性，防止某用户对系统资源的独占
- 协调多进程间的通信、同步和并发控制，防止系统死锁

标识和鉴别

- **用户标识**(User identification): 信息系统用以标识用户的一个独特符号或字符串;
- **鉴别**(Authentication): 验证用户、设备、进程和实体的身份;
- Unix/Linux的用户标识:
  - 超级用户: root
  - 普通用户: 登录系统的用户
  - 系统用户: 用于特定的系统目的
- Windows系统的用户标识:
  - 本地用户UID、组GID
  - 管理员账户、Guest账户、个人账户

标识和鉴别



可信路径管理

- 任何进入系统都需要进行用户认证，同时进行相应的用户鉴别;
- 可信路径 - 该路径上的通信只能由该用户初始化 。
- 实现可信路径
  - 能够准确辨认出用户登录的意图;
  - 提供无法冒充的用户界面;
  - 在用户认证和鉴别过程中，限制无关进程的活动;
  - 保证通信路径上的可靠性。

禁止客体重用

- **含义**：一个主体在释放资源时，一定要清除上面的信息。
- Question:
  - 内存释放后内容被清空了吗?
  - 文件删除后硬盘上没有了吗?
- 随机数抵御重放攻击

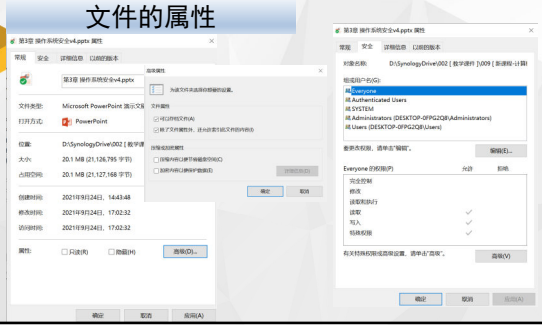
最小特权管理

- **最小特权管理**
  - 系统不应给予用户超过执行任务所需特权以外的特权。
- **实现**
  - 将超级用户的特权划分为一组细粒度的特权，使得各种操作员或者管理员只具有完成其任务所必需的特权。
- **一般系统的三种管理角色**
  - 安全管理员，审计管理员，系统管理员。

自主访问控制

- (1) 对文件的访问控制
  - Read -Copy ： 允许主体对客体进行读与拷贝的访问操作。
  - Write-delete：允许主体用任何方式修改一个客体。
  - Execute：允许主体将客体作为一种可执行文件而运行之。
  - Null ： 表示主体对客体不具有任何访问权。

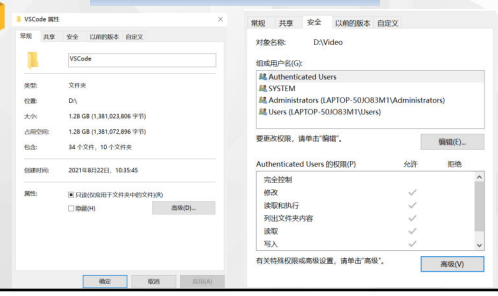
文件的属性



自主访问控制

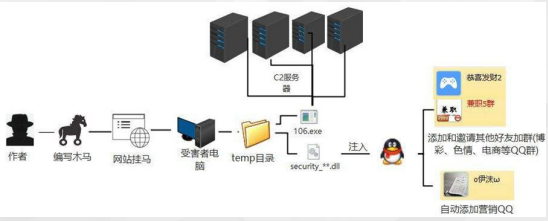
- (2) 对目录的访问控制
  - Read(读): 该模式允许主体看到目录实体，包括目录名、访问控制表以及该目录下的文件与目录的相应信息。
  - Write-Expand(写 -扩展)：该访问模式允许主体在该目录下增加一个新的客体。也就是说，允许主体在该目录下生成与删除文件或子目录。

目录的属性



利用强制访问控制减少“特洛伊木马”

- 特洛伊木马攻击



减少“特洛伊木马”攻击成功的可能方法

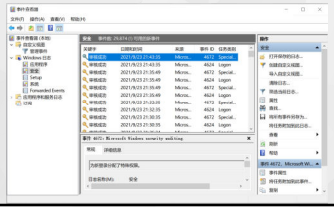
(1) 过程控制：找到C2服务器

(2) 更强的访问控制：自主访问控制+强制访问控制+附加的、更强的访问限制

- 要防止“特洛伊木马”偷窃某个文件，就必须采用强制访问控制手段
- 用户可以利用自主访问控制来防范其他用户对自己客体的攻击

安全审计(Auditing)

- 对涉及系统安全的操作做完整记录，并对这些记录进行必要的分析
- 通过事后追查增强系统安全性



36

安全审计

- **Linux系统的审计**
  - 连接时间日志：login等程序更新wtmp和utmp文件，使系统管理员能够跟踪谁在何时登录到系统
  - 进程统计：由系统内核执行。当一个进程终止时，为每个进程往进程审计文件（pacct或acct）中写一个记录。
  - 错误日志：各种系统守护进程、用户程序和内核通过syslog向文件/var/log/messages报告值得注意的事件。

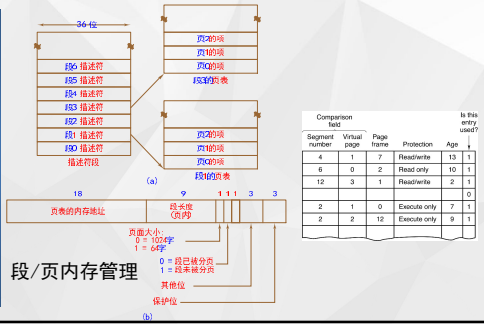
存储器的保护

存储器管理
- 有效利用存储空间。
- 保证各任务之间互不干扰。

- 操作系统对内存的保护主要采用逻辑隔离方法：
  - 界地址寄存器保护法(80x86：CS/DS/SS/ES)
  - 内存标志法：“读/写”，“只读”，“只执行”，“不能存取”
    - 锁保护法：为存储区设置的特定数字
    - 特征位保护法：在每一个存储单元的前面，设置一组特征位

特征位	数据/指令代码

存储器的保护



Comparison field					Is this entry used?
Segment number	Virtual page	Page frame	Protection	Age	
4	1	7	Read/write	13	1
6	0	2	Read only	10	1
12	3	1	Read/write	2	1
					0
2	1	0	Execute only	7	1
2	2	12	Execute only	9	1

段/页内存管理

输入/输出设备的保护

- I/O指令内容包括： I/O设备名、受影响的介质，存储缓冲区
- 访问方式：
  - 可编程的I/O操作
  - 非映射的 I/O操作
  - 预映射 I/O操作
  - 完全映射 I/O操作

R	W	C	物理设备地址

程序运行保护

溢出攻击的根源：现代计算机对数据和代码没有明确区分

DEP机制（数据执行保护，Data Execution Prevention）

- 原理：
  - 阻止数据页（如默认的堆页、各种堆栈页以及内存池页）执行代码
- 机制：
  - 软件DEP（Software DEP）：SafeSEH阻止利用S.E.H的攻击
  - 硬件DEP（Hardware-enforced DEP）：
    - AMD的No-ExecutePage-Protection (NX)
    - Intel称之为ExecuteDisable Bit (XD)

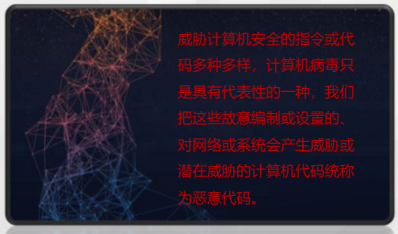
05

操作系统安全威胁和防范

漏洞威胁

系统漏洞，也可以称为系统脆弱性(Vulnerability)，是指计算机系统在硬件、软件、协议的设计、具体实现以及系统安全策略上存在的缺陷和不足。系统脆弱性是相对系统安全而言的，从广义的角度来看，一切可能导致系统安全性受影响或破坏的因素都可以视为系统安全漏洞。

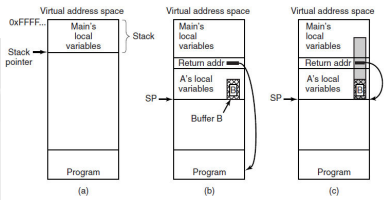
恶意代码：病毒、木马、蠕虫、间谍软件、rootkit、.....



威胁计算机安全的指令或代码多种多样，计算机病毒只是具有代表性的一种，我们把这些故意编制或设置的、对网络或系统会产生威胁或潜在威胁的计算机代码统称为恶意代码。

缓冲区溢出攻击

```
void A(){
    char B[128];
    printf("Type log message:");
    gets(B);
    writeLog(B);
}
```



操作系统安全问题总结

- **攻**：恶意软件利用操作系统的漏洞实施攻击，破坏操作系统的访问控制机制的实现，从而破坏信息系统的保密性、完整性、可靠性等
- **守**：操作系统在可信基的基础上，采取各种措施对恶意软件进行检测、防御、恢复……

CVE-2021-1732提权漏洞

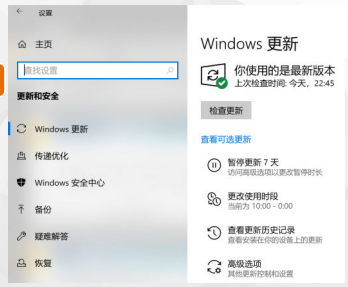
- 漏洞描述:
- **win32kfull!xxxCreateWindowEx**函数创建窗口的过程中，当创建的窗口对象存在扩展内存的时候，会通过函数KeUserModeCallback返回用户层，申请需要的内存。返回到内核继续执行的时候，会将用户层函数中指定的地址保存到窗口对象偏移0x128的pExtraBytes成员中。当用户层对窗口调用SetWindowLongPtr函数的时候，函数会将pExtraBytes用于指定要写入的目标地址。
- 通过劫持用户层函数的执行，可以让SetWindowLongPtr函数对不合法地址进行写入会产生BSOD，也可以通过计算来扩大其他窗口的cbwndExtra，从而实现任意地址读写，最终实现提权。

操作系统安全防范措施

1 系统漏洞防范措施

1. 及时更新Windows 操作系统

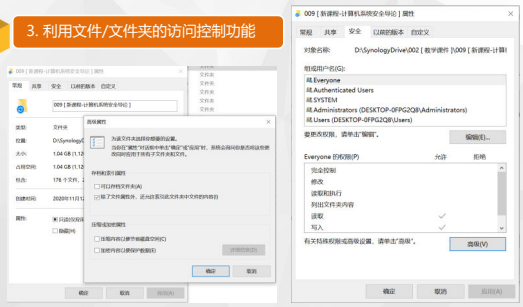
可信基 = Intel CPU+Windows



系统漏洞防范措施

2. 利用系统自带的安全中心功能

3. 利用文件/文件夹的访问控制功能



2 恶意代码防范措施

恶意代码防范措施

(1)通过正规可靠的途径去下载，购买软件资源，不要安装任何来历不明的软件。

(2)提高安全意识，不去点击任何陌生的链接，包括好友发来的链接，因为你不知道它的社交账号是否已经被盗。

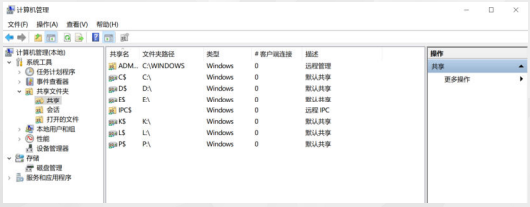
(3)查看任何邮件之前先查毒，不要因为是信任的人发来的邮件就疏于防范，因为在别人计算机上不发作的病毒，没准在自己的计算机上就会发作。

(4)及时更新系统，防堵漏洞，不给恶意代码可乘之机。

(5)开启杀毒软件监控，定期更新病毒库。

3 入侵威胁防范措施

1. 取消文件夹隐藏共享



3 入侵威胁防范措施

2. 隐藏IP地址

黑客经常利用一些网络探测技术来查看我们的主机信息，主要目的就是得到网络中主机的IP地址。IP地址在网络安全上是一个很重要的概念，如果攻击者知道了你的IP地址，就等于为攻击准备好了目标，他就可以向这个IP发动各种进攻，如DDoS (拒绝服务)攻击、Floop溢出攻击等。隐藏IP地址的主要方法是使用代理服务器。例如Hide IP Platinum软件，就能很好地隐藏你的IP地址。

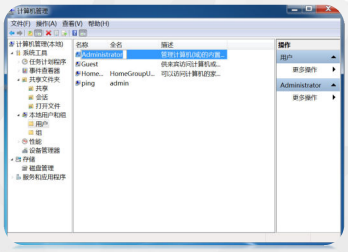
3 入侵威胁防范措施

3. 关闭不必要的端口

黑客在入侵时常常会扫描你的计算机端口，如果安装了端口监视程序(例如Netwatch)，该监视程序则会有警告提示。如果遇到这种入侵，可用工具软件关闭用不着的端口，例如，用“Norton In-ternet Security”关闭用来提供网页服务的80和443端口，其他一些不常用的端口也可关闭，比如可以通过关闭TCP 445、135、137、139端口来应对利用永恒之蓝漏洞进行入侵的行为。

3 入侵威胁防范措施

4. 更换管理员账户

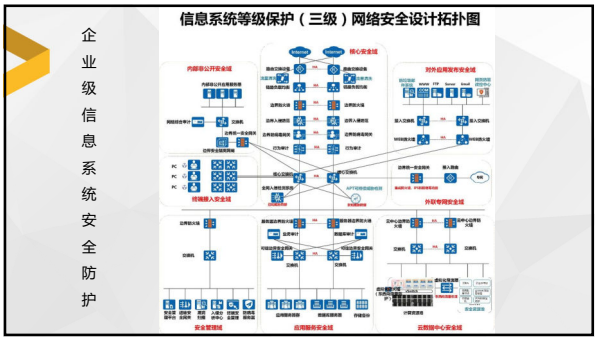


3 入侵威胁防范措施

5. 杜绝Guest账户的入侵

Guest账户即所谓的来宾账户，它虽然可以访问计算机，但受到限制。遗憾的是，Guest也为黑客入侵打开了方便之门。网上有很多文章中都介绍过如何利用Guest用户得到管理员权限的方法，因此要杜绝基于Guest账户的系统入侵。禁用或彻底删除Guest账户是最好的办法，但在某些必须使用Guest账户的情况下，就需要通过其他途径来做好防御工作了。。

3 入侵威胁防范措施
6.安装必要的安全软件
个人电脑
• Antivirus
• Firewall
• IDS
• ADGuard
• .....
Windows Defender
AVIRA
bitdefender
TREND MICRO
F-SECURE
AVG
Microsoft
PANDA SECURITY
eset
McAfee


企业级信息系统安全防护
信息系统等级保护（三级）网络安全设计拓扑图